Remediation Plan

TRACEGUARD | Evidence snapshot

INCOMPLETE COVERAGE: unknown checks must be investigated.

Schema Version
1.0

Bundle Id
31b1a622-e13d-4090-8ba7-af1c23a79690

Generated At
2026-10-31T22:05:06.537Z

Scan

Id
3557f034-3d1e-4bf8-8211-3c6b10242697

Source
ZIP upload

Created At
2026-10-31T22:04:53.126Z

Inventory Sha256
1260fb9550cb4445cfc71986b0c653f6dbaeba801b96d974c0e7074af071e7af

Coverage

Status
partial

Checked At
2026-10-31T22:05:05.982Z

Package Instances
6

Matched
5

No Known Match
1

Unknown
0

Findings Included
5

Findings Omitted
0

Limitations

1.
This report is a point-in-time snapshot of the saved inventory and fresh OSV queries, not a live deployment assessment.

2.
Dependency presence and advisory version matches do not prove runtime execution, attacker control, or actual exploitability.

3.
No known advisory match is not a safety guarantee. Unknown, failed, paginated, or skipped checks are not clean findings.

4.
Advisory IDs can be aliases of the same underlying issue; counts describe package instances, not distinct exploitable vulnerabilities.

5.
Details are fetched for at most 40 unique advisory IDs; at most 100 matched package instances and 20 advisory IDs per

finding are included. Descriptions, references, paths and source evidence are bounded.

6.
Source-provided CVSS vectors are retained without inventing numeric scores or priorities. Withdrawn or mismatched records require manual review.

7.
A verified candidate is an advisory-listed fixed release that exists in its ecosystem registry and returns no known OSV match at verification time. It is not a guarantee of safety, compatibility, or that every relevant fix was published.

8.
At most three candidate releases per package/version are checked, for at most 20 unique pairs. If no candidate is verified, manual review is required. Major-version changes may require migration.

9.
Transitive updates require changes to the owning parent or carefully reviewed root overrides. No dependency graph or lockfile is changed automatically.

10.
Only server-recorded scoped reachability results from this server process are included (latest result per instance, at most 100 instances per scan and 100 recent scans; not restored after restart). Their affected-export mappings are user-declared; NOT REACHABLE applies only within each declared coverage and is never a global safety claim.

11.
No source code, submitted package scripts, or package installation is executed while preparing these reports. Testing and release-note review remain the maintainer's responsibility.

12.
Python reachability is unsupported and UNKNOWN. PyPI fix candidates require an advisory fixed boundary, a published non-yanked release and a fresh OSV query; Python/platform compatibility is NOT TESTED. npm supply-chain heuristics do not assess PyPI packages.

13.
Dependency inventory is incomplete or has warnings; advisory coverage only applies to recorded resolved instances.

Report Type
remediation-plan

Title
Remediation Plan

Actions

1.

Finding Id
F-001

Package Node Id
urn:traceguard:component:bb86b3d2838012e8185ec413ac06bdb417c7389e 0fac7b644cbbafaab6e60255

Package Name
pyyaml

Installed Version
5.3.1

Status
VERIFIED CANDIDATE

Suggested Version
5.4

Verification

Checked At
2026-10-31T22:05:23.399Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-8q59-q68h-6hv4

2.
https://api.osv.dev/v1/vulns/PYSEC-2021-142

Registry Source

https://pypi.org/pypi/pyyaml/5.4/json

Candidate Advisory Status
no-known

Compatibility
NOT TESTED

Steps

1.
Review pyyaml 5.4, the cited PyPI advisories and your Python/platform constraints. Compatibility is NOT TESTED.

2.
Update the owning requirements/pyproject declaration or transitive parent for poetry.lock; regenerate its lockfile in your trusted development environment. TRACEGUARD does not run pip, Poetry or build backends.

3.
Review every locked instance, conditional dependency and environment marker; run project tests and rescan. No automatic edits or installs are performed.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.
Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-8q59-q68h-6hv4

2.
https://nvd.nist.gov/vuln/detail/CVE-2020-14343

3.
https://github.com/SeldonIO/seldon-core/issues/2252

4.
https://github.com/yaml/pyyaml/issues/420

5.
https://github.com/yaml/pyyaml/issues/420#issuecomment-663673966

6.
https://github.com/yaml/pyyaml/commit/a001f2782501ad2d24986959f02 39a354675f9dc

7.
https://bugzilla.redhat.com/show_bug.cgi?id=1860466

8.
https://github.com/advisories/GHSA-8q59-q68h-6hv4

9.
https://github.com/pypa/advisory-database/tree/main/vulns/pyyaml/ PYSEC-2021-142.yaml

10.
https://github.com/yaml/pyyaml

11.
https://pypi.org/project/PyYAML

12.
https://www.oracle.com/security-alerts/cpuapr2022.html

13.
https://www.oracle.com/security-alerts/cpujul2022.html

14.
https://osv.dev/vulnerability/PYSEC-2021-142

15.
https://packaging.python.org/en/latest/specifications/dependency- specifiers/

16.
https://pip.pypa.io/en/stable/cli/pip_install/

2.

Finding Id
F-002

Package Node Id
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

Package Name
requests

Installed Version
2.31.0

Status
VERIFIED CANDIDATE

Suggested Version
2.33.0

Verification

Checked At
2026-10-31T22:05:23.399Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-9hjg-9r4m-mvj7

2.
https://api.osv.dev/v1/vulns/GHSA-9wx4-h78v-vm56

3.
https://api.osv.dev/v1/vulns/GHSA-gc5v-m9x4-r6x2

4.
https://api.osv.dev/v1/vulns/PYSEC-2026-1872

5.
https://api.osv.dev/v1/vulns/PYSEC-2026-1873

6.
https://api.osv.dev/v1/vulns/PYSEC-2026-2275

Registry Source
https://pypi.org/pypi/requests/2.33.0/json

Candidate Advisory Status
no-known

Compatibility
NOT TESTED

Steps

1.
Review requests 2.33.0, the cited PyPI advisories and your Python/platform constraints. Compatibility is NOT TESTED.

2.
Update the owning requirements/pyproject declaration or transitive parent for poetry.lock; regenerate its lockfile in your trusted development environment. TRACEGUARD does not run pip, Poetry or build backends.

3.
Review every locked instance, conditional dependency and environment marker; run project tests and rescan. No automatic edits or installs are performed.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.

Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-9hjg-9r4m-mvj7

2.
https://github.com/psf/requests/security/advisories/GHSA-9hjg-9r4m-mvj7

3.
https://nvd.nist.gov/vuln/detail/CVE-2024-47081

4.
https://github.com/psf/requests/pull/6965

5.
https://github.com/psf/requests/commit/96ba401c1296ab1dda74a2365e f36d88f7d144ef

6.
https://github.com/advisories/GHSA-9hjg-9r4m-mvj7

7.
https://github.com/psf/requests

8.
https://github.com/psf/requests/releases/tag/v2.32.4

9.
https://github.com/pypa/advisory-database/tree/main/vulns/request s/PYSEC-2026-1872.yaml

10.
https://pypi.org/project/requests

11.
https://requests.readthedocs.io/en/latest/api/#requests.Session.trust_env

12.
https://seclists.org/fulldisclosure/2025/Jun/2

13.
https://osv.dev/vulnerability/GHSA-9wx4-h78v-vm56

14.
https://github.com/psf/requests/security/advisories/GHSA-9wx4-h78v-vm56

15.
https://nvd.nist.gov/vuln/detail/CVE-2024-35195

16.
https://github.com/psf/requests/pull/6655

17.
https://github.com/psf/requests/commit/a58d7f2ffb4d00b46dca2d70a3 932a0b37e22fac

18.
https://lists.fedoraproject.org/archives/list/package-announce@li sts.fedoraproject.org/message/
IYLSNK5TL46Q6XPRVMHVWS63MVJQOK4Q

19.
https://lists.fedoraproject.org/archives/list/package-announce@li sts.fedoraproject.org/message/
N7WP6EYDSUOCOJYHDK5NX43PYZ4SNHGZ

20.
https://osv.dev/vulnerability/GHSA-gc5v-m9x4-r6x2

21.
https://github.com/psf/requests/security/advisories/GHSA-gc5v-m9x4-r6x2

22.
https://nvd.nist.gov/vuln/detail/CVE-2026-25645

23.
https://github.com/psf/requests/commit/66d21cb07bd6255b1280291c4f afb71803cdb3b7

24.
https://github.com/psf/requests/releases/tag/v2.33.0

25.
https://osv.dev/vulnerability/PYSEC-2026-1872

26.
https://osv.dev/vulnerability/PYSEC-2026-1873

27.
https://github.com/advisories/GHSA-9wx4-h78v-vm56

28.
https://osv.dev/vulnerability/PYSEC-2026-2275

29.
https://packaging.python.org/en/latest/specifications/dependency- specifiers/

30.
https://pip.pypa.io/en/stable/cli/pip_install/

3.

Finding Id
F-003

Package Node Id
urn:traceguard:component:ba9445ef23336812394d0e2b9066bdaea2871f94 76e9010d489d3d37f103f597

Package Name
certifi

Installed Version
2024.7.4

Status
VERIFIED CANDIDATE

Suggested Version
2026.10.18

Verification

Checked At
2026-10-31T22:05:23.399Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-6q48-6c7w-9gw2

2.
https://api.osv.dev/v1/vulns/PYSEC-2026-4320

Registry Source
https://pypi.org/pypi/certifi/2026.10.18/json

Candidate Advisory Status
no-known

Compatibility
NOT TESTED

Steps

1.
Review certifi 2026.10.18, the cited PyPI advisories and your Python/platform constraints. Compatibility is NOT TESTED.

2.
Update the owning requirements/pyproject declaration or transitive parent for poetry.lock; regenerate its lockfile in your trusted development environment. TRACEGUARD does not run pip, Poetry or build backends.

3.
Review every locked instance, conditional dependency and environment marker; run project tests and rescan. No automatic edits or installs are performed.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.

Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-6q48-6c7w-9gw2

2.
https://github.com/certifi/python-certifi/security/advisories/GHS A-6q48-6c7w-9gw2

3.
https://discuss.python.org/t/information-for-python-users-regardi ng-emudhra-emsign-ca-certificate-security-incident/109576

4.
https://emudhra.we-have-a-problem.com/

5.
https://github.com/certifi/python-certifi

6.
https://osv.dev/vulnerability/PYSEC-2026-4320

7.
https://pypi.org/project/certifi

8.
https://github.com/advisories/GHSA-6q48-6c7w-9gw2

9.
https://packaging.python.org/en/latest/specifications/dependency- specifiers/

10.
https://pip.pypa.io/en/stable/cli/pip_install/

4.

Finding Id
F-004

Package Node Id
urn:traceguard:component:dadae6aa4447dc7e2f2119d160e1cf52b441bbc1 1d8922de0b5c6dccda99feb0

Package Name
idna

Installed Version
3.7

Status
VERIFIED CANDIDATE

Suggested Version
3.15

Verification

Checked At
2026-10-31T22:05:23.399Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-65pc-fj4g-8rjx

2.
https://api.osv.dev/v1/vulns/PYSEC-2026-215

Registry Source
https://pypi.org/pypi/idna/3.15/json

Candidate Advisory Status
no-known

Compatibility
NOT TESTED

Steps

1.
Review idna 3.15, the cited PyPI advisories and your Python/platform constraints. Compatibility is NOT TESTED.

2.
Update the owning requirements/pyproject declaration or transitive parent for poetry.lock; regenerate its lockfile in your trusted development environment. TRACEGUARD does not run pip, Poetry or build backends.

3.
Review every locked instance, conditional dependency and environment marker; run project tests and rescan. No automatic edits or installs are performed.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.
Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-65pc-fj4g-8rjx

2.
https://github.com/kjd/idna/security/advisories/GHSA-65pc-fj4g-8rjx

3.
https://nvd.nist.gov/vuln/detail/CVE-2026-45409

4.
https://github.com/kjd/idna

5.
https://github.com/pypa/advisory-database/tree/main/vulns/idna/PY SEC-2026-215.yaml

6.
https://osv.dev/vulnerability/PYSEC-2026-215

7.
https://packaging.python.org/en/latest/specifications/dependency- specifiers/

8.
https://pip.pypa.io/en/stable/cli/pip_install/

5.

Finding Id
F-005

Package Node Id
urn:traceguard:component:79493d81990b4c073997e723ca5c37c9445b6682 35b217160ee150c640fe4254

Package Name
urllib3

Installed Version
2.2.2

Status
MANUAL REVIEW

Verification

Checked At
2026-10-31T22:05:23.399Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-2xpw-w6gg-jr37

2.
https://api.osv.dev/v1/vulns/GHSA-38jv-5279-wg99

3.
https://api.osv.dev/v1/vulns/GHSA-48p4-8xcf-vxj5

4.

https://api.osv.dev/v1/vulns/GHSA-8988-9cw3-xx77

5.
https://api.osv.dev/v1/vulns/GHSA-gm62-xv2j-4w53

6.
https://api.osv.dev/v1/vulns/GHSA-pq67-6m6q-mj2v

7.
https://api.osv.dev/v1/vulns/GHSA-qccp-gfcp-xxvc

8.
https://api.osv.dev/v1/vulns/GHSA-vxq7-64xx-v4gw

9.
https://api.osv.dev/v1/vulns/PYSEC-2026-141

10.
https://api.osv.dev/v1/vulns/PYSEC-2026-1994

11.
https://api.osv.dev/v1/vulns/PYSEC-2026-1996

12.
https://api.osv.dev/v1/vulns/PYSEC-2026-1997

13.
https://api.osv.dev/v1/vulns/PYSEC-2026-1998

14.
https://api.osv.dev/v1/vulns/PYSEC-2026-1999

15.
https://api.osv.dev/v1/vulns/PYSEC-2026-4175

16.
https://api.osv.dev/v1/vulns/PYSEC-2026-4177

Candidate Advisory Status
not-verified

Compatibility
NOT TESTED

Steps

1.
No publishable, advisory-clean upgrade candidate could be verified within the report coverage. Do not assume that latest, a fixed boundary, or an unavailable query is safe.

2.
Review the cited advisories for urllib3@2.2.2, published maintainer fixes, and all owning parent paths. Verify a compatible release before choosing an upgrade.

3.
If no supported fix exists, evaluate removing or replacing the dependency, disabling the affected feature, or applying a maintainer-reviewed patch. These are manual options, not verified mitigations.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.
Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-2xpw-w6gg-jr37

2.
https://github.com/urllib3/urllib3/security/advisories/GHSA-2xpw-w6gg-jr37

3.

https://nvd.nist.gov/vuln/detail/CVE-2025-66471

4.
https://github.com/urllib3/urllib3/commit/c19571de34c47de3a766541 b041637ba5f716ed7

5.
https://github.com/urllib3/urllib3/commit/d0fde3672e4a4093f758785 8dccfc298eb66e46c

6.
https://github.com/advisories/GHSA-2xpw-w6gg-jr37

7.
https://github.com/pypa/advisory-database/tree/main/vulns/urllib3 /PYSEC-2026-1994.yaml

8.
https://github.com/urllib3/urllib3

9.
https://pypi.org/project/urllib3

10.
https://osv.dev/vulnerability/GHSA-38jv-5279-wg99

11.
https://github.com/urllib3/urllib3/security/advisories/GHSA-38jv-5279-wg99

12.
https://nvd.nist.gov/vuln/detail/CVE-2026-21441

13.
https://github.com/urllib3/urllib3/commit/8864ac407bba8607950025e 0979c4c69bc7abc7b

14.
https://lists.debian.org/debian-lts-announce/2026/01/msg00017.html

15.
https://osv.dev/vulnerability/GHSA-48p4-8xcf-vxj5

16.
https://github.com/urllib3/urllib3/security/advisories/GHSA-48p4-8xcf-vxj5

17.
https://nvd.nist.gov/vuln/detail/CVE-2025-50182

18.
https://github.com/urllib3/urllib3/commit/7eb4a2aafe49a279c29b6d1 f0ed0f42e9736194f

19.
https://github.com/urllib3/urllib3/releases/tag/2.5.0

20.
https://osv.dev/vulnerability/GHSA-8988-9cw3-xx77

21.
https://github.com/urllib3/urllib3/security/advisories/GHSA-8988-9cw3-xx77

22.
https://nvd.nist.gov/vuln/detail/CVE-2026-97687

23.
https://github.com/urllib3/urllib3/pull/5093

24.
https://github.com/urllib3/urllib3/commit/07408cec79d1856d81bb42c 74a904a24fdb9e465

25.
https://github.com/urllib3/urllib3/commit/b6447295fff7b38fdffc67e 0df9712d60cef3cc3

26.
https://github.com/urllib3/urllib3/releases/tag/2.8.0

27.
https://osv.dev/vulnerability/GHSA-gm62-xv2j-4w53

28.
https://github.com/urllib3/urllib3/security/advisories/GHSA-gm62-xv2j-4w53

29.
https://nvd.nist.gov/vuln/detail/CVE-2025-66418

30.

https://github.com/urllib3/urllib3/commit/24d7b67eac89f94e1100342 4bcf0d8f7b72222a8

31.
https://osv.dev/vulnerability/GHSA-pq67-6m6q-mj2v

32.
https://github.com/urllib3/urllib3/security/advisories/GHSA-pq67-6m6q-mj2v

33.
https://nvd.nist.gov/vuln/detail/CVE-2025-50181

34.
https://github.com/urllib3/urllib3/commit/f05b1329126d5be6de501f9 d1e3e36738bc08857

35.
https://osv.dev/vulnerability/GHSA-qccp-gfcp-xxvc

36.
https://github.com/urllib3/urllib3/security/advisories/GHSA-qccp-gfcp-xxvc

37.
https://nvd.nist.gov/vuln/detail/CVE-2026-44431

38.
https://osv.dev/vulnerability/GHSA-vxq7-64xx-v4gw

39.
https://github.com/urllib3/urllib3/security/advisories/GHSA-vxq7-64xx-v4gw

40.
https://nvd.nist.gov/vuln/detail/CVE-2026-97689

41.
https://github.com/urllib3/urllib3/commit/cd770b059b543be29298ea5 c52afb0b1b090f5ed

42.
https://osv.dev/vulnerability/PYSEC-2026-141

43.
https://osv.dev/vulnerability/PYSEC-2026-1994

44.
https://osv.dev/vulnerability/PYSEC-2026-1996

45.
https://github.com/advisories/GHSA-38jv-5279-wg99

46.
https://osv.dev/vulnerability/PYSEC-2026-1997

47.
https://github.com/advisories/GHSA-48p4-8xcf-vxj5

48.
https://osv.dev/vulnerability/PYSEC-2026-1998

49.
https://github.com/advisories/GHSA-gm62-xv2j-4w53

50.
https://osv.dev/vulnerability/PYSEC-2026-1999

51.
https://github.com/advisories/GHSA-pq67-6m6q-mj2v

52.
https://osv.dev/vulnerability/PYSEC-2026-4175

53.
https://github.com/advisories/GHSA-8988-9cw3-xx77

54.
https://osv.dev/vulnerability/PYSEC-2026-4177

55.
https://github.com/advisories/GHSA-vxq7-64xx-v4gw

56.
https://packaging.python.org/en/latest/specifications/dependency- specifiers/

57.

https://pip.pypa.io/en/stable/cli/pip_install/

Package Risk

Checked At
2026-10-31T22:05:23.400Z

Coverage

Total
6

Metadata Checked
0

Unavailable
0

Skipped
6

Results

1.

Node Id
urn:traceguard:component:bb86b3d2838012e8185ec413ac06bdb417c7389e 0fac7b644cbbafaab6e60255

Name
pyyaml

Version
5.3.1

Classification
UNKNOWN

Metadata Status
skipped

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Provenance

Status
UNKNOWN

Signatures
(none recorded)

Verification
NOT PERFORMED

Review Steps

1.
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

2.

Node Id
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

Name
requests

Version
2.31.0

Classification
UNKNOWN

Metadata Status
skipped

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Provenance

Status
UNKNOWN

Signatures
(none recorded)

Verification
NOT PERFORMED

Review Steps

1.
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

3.

Node Id
urn:traceguard:component:ba9445ef23336812394d0e2b9066bdaea2871f94 76e9010d489d3d37f103f597

Name
certifi

Version
2024.7.4

Classification
UNKNOWN

Metadata Status
skipped

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Provenance

Status
UNKNOWN

Signatures
(none recorded)

Verification
NOT PERFORMED

Review Steps

1.

PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

4.

Node Id
urn:traceguard:component:b5b7163d8af9c7df1c24eaa5f4e6bde1b389dcbe 787ca5c19c29ae2fdf4268c6

Name
charset-normalizer

Version
3.3.2

Classification
UNKNOWN

Metadata Status
skipped

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Provenance

Status
UNKNOWN

Signatures
(none recorded)

Verification
NOT PERFORMED

Review Steps

1.
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

5.

Node Id
urn:traceguard:component:dadae6aa4447dc7e2f2119d160e1cf52b441bbc1 1d8922de0b5c6dccda99feb0

Name
idna

Version
3.7

Classification
UNKNOWN

Metadata Status
skipped

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Provenance

Status
UNKNOWN

Signatures
(none recorded)

Verification
NOT PERFORMED

Review Steps

1.
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

6.

Node Id
urn:traceguard:component:79493d81990b4c073997e723ca5c37c9445b6682 35b217160ee150c640fe4254

Name
urllib3

Version
2.2.2

Classification
UNKNOWN

Metadata Status
skipped

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Comparison
NOT COMPARABLE

Artifact Verification
NOT PERFORMED

Provenance

Status
UNKNOWN

Signatures
(none recorded)

Verification
NOT PERFORMED

Review Steps

1.
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

Limitations

1.
Heuristics are review signals, not proof of malicious intent. NO SIGNALS is not a safety guarantee. Metadata can be publisher-controlled.

2.
Name similarity uses a fixed reference list v1 (react, react-dom, express, lodash, axios, typescript, webpack, vite, eslint, prettier, chalk, commander, mongoose, next, jquery, dotenv), one edit or adjacent transposition, minimum length five; scoped names are excluded. It does not cover all typosquatting or dependency confusion.

3.
At most 100 unique exact package/version pairs and 1,000 instances are included, with a 15-second metadata deadline and 1 MiB response limit. Unavailable or omitted data is not clean.

4.
Integrity compares recorded lock and registry digest strings only. Tarballs, installed bytes, signatures and provenance attestations are not downloaded or cryptographically verified. Matching metadata does not establish safety.

5.
Provenance is registry-advertised evidence only. Missing provenance or signatures does not imply malware. Lifecycle scripts are common in legitimate packages and are never executed.

6.
CONFIRMED MALICIOUS requires a fresh OSV version match and a verified, non-withdrawn MAL- advisory for the same npm package. This is an attributed source verdict, not an independent analysis; other advisory IDs and heuristics cannot confirm malware. Advisory detail coverage limits also apply.

Sources

1.
https://github.com/npm/registry/blob/main/docs/responses/package- metadata.md

2.
https://docs.npmjs.com/viewing-package-provenance/

3.
https://docs.npmjs.com/cli/v11/commands/npm-audit/

4.
https://osv.dev/

Coverage Actions

1.
Resolve manifest/lockfile inventory warnings and repeat the scan before treating coverage as complete.

2.
Validate changes in a trusted development environment. TRACEGUARD does not execute fixes or submitted source code.